Thor's Quick Sheets - CC® Domain 4

Contents

Network Basics and Definitions 2
The OSI and TCP/IP Model 2
IP Addresses, Port Numbers, and MAC Addresses / IP Support Protocols 4
Cables 4
LAN Topologies 5
Wi-Fi and Other Wireless Networks 6
VLANs and Routers / VPNs, NAC, and Third-Party Connectivity 7
SDN, SD-WAN, and SDX 8
Attacks and Attackers 8
Intrusion Detection and Prevention Systems (IDS/IPS) 9
SIEM and SOAR Systems / Honeypots and Honeynets 9
Firewalls 10
0-day Attacks and Exploits / Vulnerability Scanning and Testing 10
Virtualization, Cloud, and Distributed Computing 11
The Internet of Things (IoT / Asset Tracking and Hardware Hardening 12
Electricity and Backups 12
Fault Tolerance, Redundancy, and Resiliency 13
Fire Suppression 14
Secure Design Principles 15

Network Basics and Definitions

Networking:

- Set of computers sharing resources or data.
- Utilize defense-in-depth for internal and internet-bound data.

Simplex: One-way communication.
Half-Duplex: Send or receive at one time.
Full-Duplex: Simultaneous send and receive.
Network Types:

- **Baseband:** Single channel, one signal at a time (e.g., Ethernet).
- **Broadband:** Multiple channels, multiple signals at once.

Internet: Global collection of peered WAN networks.
Intranet: Private network within an organization.
Extranet: Connection between private Intranets.
Circuit Switching: Dedicated communication channel, guarantees bandwidth.
Packet Switching: Data sent in packets over multiple paths, no capacity guarantee. Uses QoS for traffic priority.
PAN (Personal Area Network): Close-range network around an individual.
LAN (Local Area Network): Network within a limited area (e.g., building).
MAN (Metropolitan Area Network): Network spanning a city or large campus.
WAN (Wide Area Network): Network covering large geographic areas.
GAN (Global Area Network): Supports mobile users across multiple wireless LANs.
VPN (Virtual Private Network): Sends private data over an insecure network, simulates private network experience over the internet.

The OSI and TCP/IP Model

The OSI Model:

- Standardizes communication functions across systems with different technologies.
- Divides communication into 7 abstraction layers.

Layers:

1. **Physical Layer:** Hardware components like wires, fiber optics, and NICs.
   - **Topologies:** Bus, Star, Ring, Mesh.
   - **Threats:** Eavesdropping, interference.
2. **Data Link Layer:**
   - Transports data between nodes on the same network.
   - Handles MAC addresses and error detection.
   - **ARP (Address Resolution Protocol)** Layer 2/3.
   - **CSMA/CD:** Ethernet – minimized with switches vs. hubs.
   - **CSMA/CA:** Wireless.
   - **Threats:** MAC spoofing, flooding.

3. **Network Layer:** Manages IP-based communications.
   - **Protocols:** IP, ICMP, IPSEC.
   - **Threats:** Ping of Death, IP modifications.
4. **Transport Layer:** Provides reliable (TCP) or connectionless (UDP) data transfer.
   - **UDP (User Datagram Protocol):** Connectionless protocol, unreliable, VOIP, live video, gaming, "real time''.
     - **Threats: Fraggle attack**
   - **TCP (Transmission Control Protocol):** Reliable, connection orientated, guaranteed delivery, 3-way handshake.
     - **Threats: SYN floods.**
5. **Session Layer:** Manages sessions between applications.
6. **Presentation Layer:** Formats, compresses, and encrypts data.
7. **Application Layer:** Interfaces with user applications (e.g., HTTP, HTTPS).
   - **Threats to Level 5-7:** Viruses, worms, application vulnerabilities.

- **Key Concepts:**
  - **Simplex, Half-Duplex, Full-Duplex:** Communication types.
  - **Baseband vs. Broadband:** Single vs. multiple channels.
  - **PDU (Protocol Data Units):** Data, Segments, Packets, Frames, Bits.
  - Higher layers offer more intelligence but slower speed.

The TCP/IP Model:

- Provides end-to-end data communication.
- Specifies data packetization, addressing, transmission, routing, and receiving.

Layers (Lowest to Highest):

- **Link Layer:**
  - Manages data transfer within a single network segment.
  - Handles MAC addresses and packet header preparation.
  - Equivalent to OSI Layers 1-2.
- **Internet Layer:**
  - Responsible for routing packets across multiple networks.
  - Functions: Host addressing (IP addresses) and packet routing.
  - Equivalent to OSI Layer 3.
- **Transport Layer:**
  - Establishes data channels for applications (TCP/UDP).
  - Manages error control, segmentation, flow control, and port numbers.
  - Equivalent to OSI Layer 4.
- **Application Layer:**
  - Provides protocols for user services and data exchange (e.g., HTTP, FTP).
  - Equivalent to OSI Layers 5, 6, and 7.

Encapsulation:

- Each layer adds or removes encapsulation.
- Higher layers offer smarter but slower operations.

Routers/Switches:

- Generally do not interpret encapsulated traffic.
- Firewalls and bandwidth controls may interpret application data.

User vs. Support Protocols: Differentiated within the application layer.

IP Addresses, Port Numbers, and MAC Addresses / IP Support Protocols

MAC Addresses:

- Unique network card identifier (48-bit MAC-48 or 64-bit EUI-64).
- First 24 bits: manufacturer; remaining bits: unique host ID.
- Can be easily spoofed.

IP Addresses:

- **IPv4:** 32-bit, ~4.2 billion addresses; connectionless, no delivery guarantees.
- **IPv6**: 128-bit, vast address space, includes IPSec.
- **Public IPs:** Internet routable.
- **Private IPs:** Non-routable (e.g., 10.0.0.0, 172.16.0.0, 192.168.0.0).

Ports:

- **Well-known Ports:** 0-1023 (e.g., HTTP 80, HTTPS 443). Mostly used for products.
- **Registered Ports:** 1024-49151. Mostly used for vendor specific applications.
- **Dynamic, Private or Ephemeral Ports: 49152-65535.** Can be used by anyone.

IP Support Protocols

- **ARP:** Translates IP to MAC; vulnerable to poisoning.
- **ICMP:** Troubleshooting (e.g., Ping, Traceroute).
- **Traceroute:** Uses ICMP to trace network paths.
- **HTTP/HTTPS:**
  - **HTTP:** Unencrypted, TCP port 80.
  - **HTTPS**: Encrypted, TCP port 443.
- **DHCP:** Assigns IPs dynamically; uses UDP ports 67 (server) and 68 (client).

Cables

Networking Cables:

- Various types beyond RJ45 Ethernet.
- Each type has pros and cons: cost, security, speed.
- Vulnerabilities **include EMI, crosstalk, and attenuation**.

Twisted Pair Cables:

- **UTP (Unshielded Twisted Pair):**
  - Less susceptible to EMI due to twisted design.

  - More twists = less EMI (e.g., CAT6 vs. CAT3).
- **STP (Shielded Twisted Pair):** Metal shielding reduces EMI but increases cost and stiffness.
- **Fiber Optic Cables:** Uses light, not electricity.
  - Pros:
    - High speed (up to 1 Pbps), long distances (150+ miles).
    - Immune to EMI, more secure.
  - Cons:
    - Expensive, fragile.
  - **Types:**
    - Single-Mode: Single light mode, long distances.
    - Multi-Mode: Multiple light modes, uses WDM for data streams.

Data Transfer Rates:

- **Kbps:** 1,000 bps
- **Mbps:** 1,000,000 bps
- **Gbps:** 1,000,000,000 bps
- **Tbps:** 1,000,000,000,000 bps
- **Pbps:** 1,000,000,000,000,000 bps

LAN Topologies

LAN Topologies

- Describes the layout of interconnections between devices.
- Common technologies: **Ethernet and Wi-Fi**.
- Topologies include ring, bus, mesh, and star.
- **Bus Topology:**
  - Nodes connected in a line; each inspects and passes traffic.
  - Single cable break disrupts all subsequent nodes.
- **Tree (Hierarchical) Topology:** Traffic controlled by the base (e.g., mainframe).
- **Ring Topology:** Nodes connected in a closed loop.
- **Star Topology:**
  - Nodes connected to a central device (e.g., switch).
  - Improved fault tolerance: cable break affects only one node.
  - Switches prevent collisions, unlike hubs.
- **Mesh Topology:**
  - **Partial Mesh:** Some nodes directly connected.
  - **Full Mesh:** All nodes directly connected to each other.
  - High redundancy, often used in high availability environments.

Wi-Fi and Other Wireless Networks

Wi-Fi:

- Wireless network linking devices in a limited area.
- Often uses multiple APs for seamless coverage.
- Based on IEEE 802.11 standards (Wi-Fi).

Security Concerns:

- Easier to compromise than wired connections.

Wi-Fi Attacks:

- **Rogue Access Points:**
  - Unauthorized APs added without knowledge.
  - Mitigated by port security and scanning.
  - Risks confidentiality and integrity.
- **Jamming/Interference:**
  - Disruption via traffic overload or intentional jamming.
  - Mitigated by changing channels or frequencies.
  - Risks integrity and availability.
- **Evil Twin:**
  - Fake AP mimicking legitimate ones.
  - Risks confidentiality and integrity.

Wireless Networks

- **Bluetooth:**
  - Short-distance wireless communication standard using 2.4 GHz.
  - **Device classes:** Class 1 (100m), Class 2 (10m), Class 3 (<10m).
  - **Security:** Uses E0 stream cipher; vulnerable to attacks like Bluejacking, Bluesnarfing, Bluebugging.
  - **Countermeasures:** Enable only when needed, disable discovery, update firmware.
- **Li-Fi:**
  - Uses light for high-speed data transmission.
  - Suitable for EMI-prone areas (e.g., hospitals).
  - **Pros:** High speeds, can be used where Wi-Fi is prohibited.
  - **Cons:** Short-range, high implementation cost.
- **Zigbee:**
  - Low power, low data rate mesh network.
  - **Range:** 10-100 meters, requires line-of-sight.
  - **Data rates:** 20-250 kbit/s.
- **Satellite:**
  - Internet via satellite dish and modem.
  - **Latency:** historically ~500 ms, Starlink: 15-40 ms.
  - **Speeds:** Starlink ~20-200 Mbps down, 15-50 Mbps up.

- **Cellular Networks:**
  - Divided into cells with transceivers for coverage.
  - **3G:** 2 Mbps bandwidth, 100-500 ms latency.
  - **4G:** 200 Mbps bandwidth, 20-30 ms latency, 25 Mbps average speed.
  - **5G:** 5-20 Gbps bandwidth, <10 ms latency, 200-400 Mbps average speed, short-range, blocked by solid objects.

VLANs and Routers / VPNs, NAC, and Third-Party Connectivity

VLANs and Routers

Layer 2 Protocols:

- **VLAN (Virtual LAN):**
  - Isolates network segments at layer 2.
  - Ports on a switch assigned to specific VLANs.
  - Allows separate networks to share physical devices without interaction.
  - Uses tags in network packets to simulate a split network.
  - **VLAN Trunks:** Connect switches to span VLANs; can use link aggregation and QoS.
- **Virtual eXtensible LAN (VXLAN):**
  - Used for cloud computing with multiple tenants.
  - Addresses the limitation of 4094 maximum VLANs.

Layer 3 Devices:

- **Routers:**
  - Typically fewer ports than switches; found in data centers or combined devices at home.
  - Forward traffic based on IPs and ports, connecting LANs to WANs.
  - Use routing tables for traffic direction.
  - **Static Routes:** Preconfigured paths for specific subnets.
  - **Default Gateway:** Routes non-local traffic.
  - **Dynamic Routes:** Learned from protocols like OSPF, EIGRP, BGP.
  - **Metric:** Determines the best route to a destination.

VPNs, NAC, and Third-party Connectivity

- **VPN (Virtual Private Network):**
  - Extends a private network over a public network.
  - Allows secure data transmission as if on a private network.
  - Enables secure access to an organization's intranet for remote users.
  - Utilizes virtual tunnels, dedicated connections, and encryption.
- **Third-party Connectivity:**
  - Medium-sized enterprises often engage multiple third-party providers.
  - Conduct risk assessments to maintain security posture.
  - Utilize MOUs/MOAs and ISAs for security agreements.

- **Network Access Control (NAC):**
  - Ensures systems comply with security policies automatically.
  - Maintains adherence to security policies consistently.

SDN, SD-WAN, and SDX

SDN (Software-Defined Networking):

- Enables dynamic network management via software.
- Separates control plane (routing decisions) from data plane (data forwarding).
- Supports modern, scalable computing environments like data centers.

SD-WAN (Software-Defined Wide Area Network):

- Widely adopted for its bandwidth flexibility and cost-effectiveness.
- Supports diverse connection types (DSL, fiber, satellite, 4G/5G).
- Facilitates rapid deployment and secure connectivity with IPSec and next-gen firewalls.

SDx (Software-Defined Everything):

- Encompasses any function automated or performed by software.
- Includes networking, storage, data center, compute, security, WAN, etc.

Attacks and Attackers

Hackers:

- **White Hat:** Ethical hackers, identify vulnerabilities to fix.
- **Black Hat:** Malicious hackers, exploit vulnerabilities.
- **Gray Hat:** In-between, find vulnerabilities without explicit permission.
- **Script Kiddies:** Use hacking tools with little coding knowledge.

Types of Attackers:

- **Outsiders:** Unauthorized individuals, launch majority of attacks, often intercepted by defense measures.
- **Insiders:** Authorized individuals, intentional or unintentional compromises.
- **Hacktivists:** Hack for political or social causes.
- **Government:** State-sponsored hacking, targeting systems for strategic purposes.

Bots and Botnets:

- **Bots:** Compromised systems controlled remotely, often used for spam or data theft.
- **Botnets:** Networks of bots controlled by a command and control center.

Malware:

- **Viruses:** Require human action, replicate by inserting code.
  - **Types:** Macro, Boot Sector, Stealth, Polymorphic, Multipart.
- **Worms:** Self-propagating, no human interaction needed.
- **Trojans:** Malicious code within legitimate programs; RATs provide remote control.

Antivirus Software:

- **Signature-Based:** Detects known malware signatures, needs frequent updates.
- **Heuristic-Based:** Detects abnormal behavior, prone to false positives.

Intrusion Detection and Prevention Systems (IDS/IPS)

IDS and IPS are used to detect and/or block malicious network traffic.

- **IDS:** Passive, monitors and alerts without action.
- **IPS:** Active, takes action to block or redirect malicious traffic.

Types:

- **Network-Based:** Monitors network segments, can't inspect encrypted traffic.
- **Host-Based:** Monitors individual systems, can inspect decrypted data.

Detection Methods:

- **Signature-Based:**
  - Matches traffic against known malicious patterns.
  - Vulnerable to zero-day attacks; requires constant updates.
- **Heuristic-Based (Behavioral):**
  - Detects abnormal behavior based on a baseline.
  - Can result in false positives, requires tuning.
- **Hybrid-Based:** Combines signature and heuristic methods.

Intrusion Events and Masking: Attackers use techniques like fragmentation, unexpected ports, and low-bandwidth attacks to evade detection.

Alert Categories:

- **True Positive:** Correct detection and response to an attack.
- **True Negative:** Correctly identifies normal traffic.
- **False Positive:** Mistakenly identifies normal traffic as an attack.
- **False Negative:** Fails to detect an actual attack.

SIEM and SOAR Systems / Honeypots and Honeynets

SIEM and SOAR Systems

- **SIEM (Security Information and Event Management):**
  - Provides a comprehensive view of organizational events and incidents.
  - Collects and analyzes data from all systems for monitoring purposes.
- **SOAR (Security Orchestration, Automation, and Response):**
  - Uses AI to automate and respond to certain security incidents.
  - Enhances reaction capabilities to events.

Honeypots and Honeynets

- **Honeypots:**
  - Systems designed to appear as legitimate targets to attract attackers.
  - Used to study vulnerabilities and attacker strategies.
- **Honeynets:**
  - A network of honeypots, possibly simulating a full server farm.
  - Best practice is to isolate from the main network using a DMZ/firewall.
  - Data from honeynets is collected by SIEM/SOAR for analysis.

Firewalls

Firewalls: Establishes a barrier between a trusted internal network and external networks like the Internet.

Types of Firewalls:

- **Packet Filtering Firewalls (OSI Layers 1-3):**
  - Inspects packets against filtering rules.
  - Drops/rejects packets not matching rules.
  - Rules checked sequentially.
- **Stateful Filtering Firewalls (OSI Layers 1-4):**
  - Tracks state of connections.
  - Utilizes static rules with connection state criteria.
  - Vulnerable to connection-based DoS attacks.
- **Proxy Servers:** Acts as a gateway, filtering traffic for specific applications.
- **Application Layer Firewalls (OSI Layer 7):**
  - Understands specific applications and protocols.
  - Inspects entire packet payloads.
  - Detects malicious use of allowed protocols.

Network vs. Host-Based Firewalls:

- **Network Firewalls:** Filter traffic between networks, can be software or hardware-based.
- **Host-Based Firewalls:** Software security on individual hosts.

Next-Generation Firewalls (NGFW):

- Combines traditional firewalls with deep packet inspection and security systems.
- Inspects packet contents beyond headers for enhanced security.

Firewall Design:

- **DMZs (Demilitarized Zones):**
  - Use one or two firewalls to expose external services securely.
  - Enhance security by limiting external access to only DMZ services.
  - Often use redundancy and mesh topology for reliability.

0-day Attacks and Exploits / Vulnerability Scanning and Testing

0-day Attacks and Exploits

0-day Vulnerabilities:

- Newly discovered vulnerabilities not yet widely known.
- "Day 0" refers to the first day the vulnerability is identified.
- Patches or security signatures are typically released shortly after discovery.

Defense Against 0-day Exploits:

- Employ defense in depth strategies.
- Patch systems immediately upon release and after testing.
- Ensure IDS/IPS and antivirus systems auto-update with new signatures.

0-day Vulnerability: Undiscovered and unpublished security flaw.

0-day Exploit: Code leveraging the vulnerability.

0-day Attack: Execution of the exploit.

- Example: Stuxnet:

Components:

- **Worm:** Executes attack routines.
- **Link file:** Executes worm copies.
- **Rootkit:** Hides malicious files/processes.

Propagation:

- Introduced via infected USB.
- Targets Siemens Step7 software and PLCs.
- Modifies PLC codes and masks malicious activity, simulating normal operations.

Vulnerability Scanning/Testing:

- Scans networks or systems for predefined vulnerabilities (e.g., misconfigurations, outdated software, unpatched systems).

Key Points:

- Understanding scan outputs is crucial; reports can be extensive.
- Analyzing how vulnerabilities relate to threats and risks (Risk = Threat x Vulnerability) is essential.
- Proper risk assessment allows for effective mitigation planning.

Virtualization, Cloud, and Distributed Computing

Virtualization: Hosts multiple virtual servers (clients) on a single hardware platform.

- Benefits: Cost reduction, easy server setup, resource allocation, smaller physical footprint.

Hypervisors:

- **Type 1 (Bare Metal):** Runs directly on hardware.
- **Type 2:** Runs on an existing OS.
- Security Concerns: VM escape, hypervisor access, resource exhaustion.
- Clients should be logically separated like physical servers.

VM Escape (Virtualization escape): When an attacker can jump from the host or a client to another client, this can be even more of a concern if you have different Trust Level Clients on the same host.

Hypervisor Security: If an attacker can get access to the hypervisor, they may be able to gain access to the clients.

Cloud Computing: Outsourcing IT infrastructure, storage, or applications to external providers.

- **Private:** Owned by a single organization.
- **Public:** Shared infrastructure rented out (e.g., AWS, Google).
- **Hybrid:** Combination of private and public.
- **Community:** For specific groups with shared concerns.
- **Models:** IaaS, PaaS, SaaS.

Distributed Systems:

- Collection of systems working together as a single entity.

- Benefits: Horizontal scaling, fault tolerance, cost-effectiveness, low latency.
- Used in internet, P2P networks, blockchain, etc.
- High-Performance Computing (HPC):
- Aggregates compute nodes for complex calculations at high speeds.
- **Components:** Compute, network, storage.

Edge Computing:

- Processes data close to its source to optimize bandwidth and reduce latency.
- Commonly used in CDNs.
- Widely adopted by large enterprises.

The Internet of Things (IoT / Asset Tracking and Hardware Hardening

The Internet of Things (IoT): Refers to "smart" devices like TVs, thermostats, lightbulbs, cars, etc., that connect to the internet.

- Security Concern: Many IoT devices lack patching capabilities, leaving them vulnerable to attacks.

Asset Tracking and Hardware Hardening

- **Asset Tracking:**
  - Essential for maintaining an accurate inventory of all organizational assets.
  - Important for risk analysis and technology refresh cycles.
  - Record details like Asset Serial Number, Model Number, and Asset ID.
- **Hardware Hardening:**
  - **Servers:** Apply patches, block unnecessary ports, remove default users.
  - **Workstations:** Often overlooked; hardening is crucial.
  - **Disabling Ports:**
    - USB ports, CD drives, etc., should be disabled to prevent malware.
    - Methods include physical blocking or disabling via motherboard; effectiveness varies.

Electricity and Backups

Electricity

- Ensures clean, reliable power for servers, network equipment, and disk arrays.
- Power loss affects availability and data integrity.

Blackout: Prolonged power loss.
Fault: Brief power loss.
Brownout: Extended low voltage.
Sag: Brief low voltage.
Surge: Extended high voltage.
Spike: Brief high voltage.
Protection Devices:

- **Surge Protectors:** Shield equipment from high voltage.

- **UPS (Uninterruptible Power Supply):**
  - Provides constant clean power and temporary backup during outages.
  - Acts as a surge protector.
- **Generators:**
  - Auto/manual operation during power outages.
- **PDU (Power Distribution Unit):** Distributes power within a rack or facility.

Backups

Fault Tolerance:

- Ensures high availability and redundancy.
- Backups are crucial for fault tolerance but often overlooked.

Backup Types:

- Full Backup:
  - Backs up everything in the policy.
  - Clears archive bits.
  - Used for complete restores, but time-consuming.
  - Example: Restore with a single full backup tape.
- **Incremental Backup:**
  - Backs up changes since the last backup.
  - Clears archive bits.
  - Fast to perform but requires multiple tapes for full restoration.
  - Example: Restore with full backup and all subsequent incremental tapes.
- **Differential Backup:**
  - Backs up changes since the last full backup.
  - Does not clear archive bits.
  - Faster restoration with only two tapes (full and differential).
  - Example: Restore with full backup and latest differential tape.
- **Copy Backup:**
  - Full backup that does not clear archive bits.
  - Used before system updates to avoid disrupting backup cycles.
- **Archive Bit:** NTFS flag indicating file changes since the last full or incremental backup.

Fault Tolerance, Redundancy, and Resiliency

RAID (Redundant Array of Independent/Inexpensive Disks):

- **Disk Mirroring:**
  - Data written to multiple disks for redundancy; requires at least 2 disks.
  - Slower due to writing data twice.
- **Disk Striping:**
  - Data spread across multiple disks for speed; requires at least 2 disks.
  - No redundancy unless combined with parity.

RAID Types:

- **RAID 0:** Striping with no redundancy; requires 2 disks.
- **RAID 1:** Mirroring for redundancy; requires 2 disks.
- **RAID 5:** Striping with distributed parity; requires at least 3 disks for speed and redundancy.

System Redundancy:

- Provides additional fault tolerance beyond RAID and backups.
- Common failures: Disks, fans, power supplies (PSUs).
- Use redundant components like PSUs, NICs, and disk controllers.
- Hot-swappable hardware (e.g., HDDs, PSUs) for quick replacements.
- Clustering:
  - Multiple servers act as a single unit for fault tolerance. Can be active/active for load balancing.
- **Database Shadowing:** Real-time duplication of data to another location.
- **Electronic Vaulting:** Remote backups sent off-site electronically.
- **Remote Journaling:** Transaction logs sent to a remote site, not full files.

Fire Suppression

Fire Requirements:

- A fire needs Oxygen, Heat, and Fuel.
- Extinguishing a fire requires removing one of these elements.

Methods of Suppression:

- **Removing Oxygen:** Use agents like Halon, FM200, or Argon to displace oxygen.
- **Removing Heat:** Apply chemicals or water to cool the fire.
- **Removing Fuel:** Rarely done as the equipment is often the fuel.

Fire Classes: Considered from a security perspective in a top-down organization.

Automatic Fire Suppression Systems:

- **Water Systems:**
  - Reduces heat, but can damage hardware.
  - Should disconnect electricity before use.
- **Sprinkler Systems:**
  - Trigger independently based on temperature.
  - **Wet Pipe:** Contains water up to the sprinkler.
  - **Dry Pipe:** Contains compressed air, releases water when triggered.
- **Fire Extinguishers:**
  - Used for small fires in emergencies.
  - Marked for specific fire types.
  - **PASS Method**:
    - **P**ull the pin.
    - **A**im at the base.
    - **S**queeze the lever.
    - **S**weep side to side.

Secure Design Principles

Least Privilege: Employees receive only the access necessary for their role.
Need to Know: Access to data is restricted to those who need it for their tasks.
Separation of Duties:

- Tasks are divided among multiple individuals to prevent fraud.
- Compensating controls are needed if separation isn't practical.

Defense in Depth:

- Multiple, overlapping security controls protect assets.
- Includes physical, administrative, and logical measures.

Secure Defaults:

- Systems are as secure as possible upon implementation.
- Security can be adjusted for usability as needed.

Fail Securely:

- Systems maintain security even if they fail.
- Design for secure outcomes in failure scenarios.

Keep It Simple: Simple security measures are easier to manage and understand.
Trust but Verify: Implicit trust with verification, especially for privileged users.
Zero Trust:

- No implicit trust for devices or users; always verify.
- Focus on user, asset, and resource security.

Privacy by Design:

- Privacy is integrated into the design process.
- Emphasizes proactive protection and transparency.

Shared Responsibility: In cloud computing, security is a shared duty between provider and customer.